

As for programming errors, a user input taken from a Web application form may be directly sent to a backend database server without parsing it. This can lead to a parameter manipulation attack or SQL injection attack. Another example of programming errors would be a Web service accepting requests without performing adequate authentication, thus leaking data inadvertently. This shows us that it is human error that leads to vulnerable systems, which could be exploited easily by attackers, to compromise data confidentiality, integrity and availability.

What is vulnerability assessment?

Vulnerability assessment (VA) is a systematic technical approach to find the security loopholes in a network or software system. VA is entirely a process of searching and finding, with the objective that none of the loopholes are missed. It primarily adopts a scanning approach which is done both manually and performed by certain tools. The outcome of a VA process is a report showing all vulnerabilities, which are categorised based on their severity. This report is further used for the next step, which is penetration testing (PT). VA is usually a non-intrusive process and can be carried out without jeopardising the IT infrastructure or application's operations.

What is penetration testing?

A penetration test (PT) is a proof-of-concept approach to actually explore and exploit vulnerabilities. This process confirms whether the vulnerability really exists and further proves that exploiting it can result in damage to the application or network. The PT process is mostly intrusive and can actually cause damage to the systems; hence, a lot of precautions need to be taken before planning such a test. The outcome of a PT is, typically, evidence in the form of a screenshot or log, which substantiates the finding and can be a useful aid towards remediation. As a summary, shown below are the steps involved in the VAPT process.

- Scanning the network or application
- Searching for security flaws
- Exploiting the security flaws
- Preparing the final report of the test

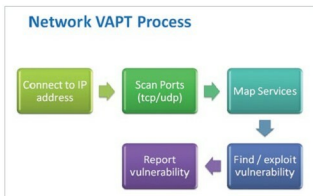


Figure 1: Network VAPT process



Figure 2: Web VAPT process

Differences between VA and PT

VA and PT differ from each other in two aspects. The VA process gives a horizontal map into the security position of the network and the application, while the PT process does a vertical deep dive into the findings. In other words, the VA process shows how big a vulnerability is, while the PT shows how bad it is. There is one more subtle difference. Due to the nature of work involved in each process, a VA can be carried out using automated tools, while a PT, in almost all cases, is a manual process. This is because PT essentially simulates what real hackers would do to your network or application. Figures 1 and 2 show the VAPT process for network and Web applications, respectively.

VAPT tools

While there are multiple tools available in the market, those listed below are well-known for their usability. Although these tools are mentioned as VAPT tools, most of them essentially provide VA only and leave the PT part to the ethical hackers to be done manually. There are a couple of tools, though, which are powerful PT tools, and are mentioned as such in the list below.

- Nmap
- Acunetix
- Nessus
- OpenVAS
- Nexpose
- BurpSuite (PT)
- Metasploit (PT)

There are two important terms that an ethical hacker must know, especially while using these tools. These are: false positive and false negative.

A false positive is when a vulnerability actually does not exist, but it gets reported. A false negative is when a vulnerability actually exists but it is not reported. A false positive can be a nuisance resulting in a waste of time for an ethical hacker, whereas a false negative can be really

Continued on page 40...